

2.3 System Hardening

Control Type: Mandatory	Applies to architecture:	A1	A2	A3	A4	B
		•	•	•	•	•
<u>Control Definition</u> Control Objective: Reduce the cyber-attack surface of Swift-related components by performing system hardening. In-scope components: • dedicated and general-purpose operator PC • jump server • systems (physical or VMs) hosting a Swift-related component (including interface, GUI, Swift and customer (client) connectors) • customer client connector • on-premises or remote (that is hosted or operated by a third party, or both) virtualisation or cloud platform (also referred to as the hypervisor) hosting Swift-related VMs, including those hosting the Alliance Connect Virtual on Premises VPN, and their management PCs • network devices protecting the secure zone or the customer client connectors • bridging servers (such as middleware or file transfer servers other than customer connectors) used for and guardian of the secure data exchange between back-office and Swift-related components Note: Swift HSMs are FIPS 140-2 Level 3 compliant with hardened underlying OS and are out of the scope of this control. Similarly, all the Alliance Connect VPNs are shielded and managed by Swift and are out of scope of this control. Risk Drivers: • excess attack surface • exploitation of insecure system configuration						
<u>Implementation Guidance</u> Control Statement: Security hardening is conducted and maintained on all in-scope components. Control Context: System hardening applies the security concept of “least privilege” to a system by disabling features and services that are not required for normal system operations. This process reduces the system capabilities, features, and protocols that a malicious person may use during an attack. Implementation Guidelines: The implementation guidelines are common methods to apply the relevant control. The guidelines are a helpful way to begin an assessment but should never be considered as an audit checklist as each user’s implementation may vary. Therefore, in cases where some implementation guidelines elements are not present or partially covered, mitigations as well as particular environment specificities must be considered to properly assess the overall compliance adherence level (as per the suggested guidelines or as per the alternatives). • All in-scope systems are hardened, considering one or more of the following: – vendor security configuration guidance						

- industry-standard security configuration guidance (for example,²³ [CIS](#), [DISA STIG](#), or [NIST](#) which also offer guidance for virtualisation and container platforms)
- a local or regulator's standard security configuration, or controls set of the same rigour as the vendor or industry guidance
- The selected hardening configuration (set of rules) can be overruled by application-specific configuration requirements to maintain a proper operational state for Swift-related systems.
- At a minimum, the hardening process should do the following:
 - Change default passwords.
 - Disable or remove unnecessary user accounts.
 - Disable or restrict unnecessary services, ports, and protocols.
 - Remove unnecessary software or control usage of native OS admin features (such as Windows Management Instrumentation, or PowerShell).
 - Restrict physical ports (for example, USBs or serial bus) as appropriate, by disabling them to the maximum extent possible, while still supporting operations (for example, when USB tokens are required to authenticate users, for message operations or other operational tasks).
 - Set, when technically possible, auto-lock options (such as activating an operator PC screen saver requiring a login after an inactivity time-out or when turned to sleep mode). A 15-minute inactivity time-out is recommended.
 - Adjust any default configurations known to be vulnerable.

The vendor and industry standards listed above can provide detailed guidance to accomplish these minimum targets.

- Deviations from the selected hardening configuration are documented along with justification for the deviation and potential mitigations applied.
- Systems are maintained secure, as follows:
 - by checking regularly (at least twice per year) the systems against the secure settings identified as per preceding guidance to take any relevant corrective actions
 - by regularly applying the identified secure settings to the systems.

Optional Enhancement:

- Systems within the secure zone implement application allowlisting on the operating system which allows only known and trusted applications to be executed.
- Apply the control to all bridging servers (such as middleware or file transfer servers other than customer connectors) used for data exchange between back-office and Swift-related components.

²³ Center for Internet Security; Defense Information Systems Agency - Security Technical Implementation Guide; National Institute of Standards and Technology